

SUPNUM

DSI/DWM

Examen Final

Sécurité des Réseaux et Systèmes

Année Universitaire : 2025-2026

Durée : 3 Heures

Consignes et Déroulement de l'Examen

Cet examen valide vos compétences opérationnelles. L'accès à Internet et aux assistants IA est autorisé, mais la réalisation technique est obligatoire.

- Livrable : Un rapport PDF contenant obligatoirement les captures d'écran de vos terminaux et navigateurs.
- Authenticité : Chaque capture d'écran doit inclure une commande affichant votre Nom complet et Matricule (ex : via un echo). Toute capture d'écran sans cette preuve sera invalidée.

Préparation de l'Environnement

Avant de commencer les épreuves de fuzzing et d'attaque par dictionnaire, vous devez récupérer les fichiers nécessaires depuis le serveur de l'examen. Exécutez les commandes suivantes dans votre terminal :

```
# 1. Dictionnaire pour le Fuzzing
wget http://192.168.9.6:8181/wordlist.txt -O wordlist.txt

# 2. Dictionnaires pour l'attaque d'authentification (Hydra)
wget http://192.168.9.6:8181/users.txt -O users.txt
wget http://192.168.9.6:8181/passwords.txt -O passwords.txt
```

Listing 1 – Téléchargement des ressources

Partie 1 : Déploiement et Sécurisation de Services (5 points)

Cette partie se déroule localement sur votre propre machine virtuelle ou Host.

1. **Génération de Certificat SSL/TLS** : Utilisez `openssl` pour générer un certificat auto-signé valide pour 365 jours.
2. **Déploiement HTTPS** : Configurez un serveur web local (Apache ou Nginx au choix) pour utiliser ce certificat et écouter sur le port 443.
3. **Preuve de configuration** : Modifiez la page d'accueil par défaut (`index.html`) pour qu'elle affiche en grand format : *"Serveur Sécurisé de [Votre Nom] - [Votre Matricule]"*.
4. **Livrable exigé** : Fournissez une capture d'écran de votre navigateur accédant à `https://localhost` ou `https://127.0.0.1`. La capture doit montrer l'avertissement de certificat auto-signé (cadenas barré) ET le contenu de la page avec votre nom.

Partie 2 : Audit de l'Infrastructure Cible (5 points)

Connectez-vous au VPN. Assurez-vous d'avoir accès à l'IP cible de l'examen (192.168.9.6).

1. **Énumération Initiale** : Effectuez un scan agressif (-A) avec Nmap sur la cible pour identifier les ports ouverts, les services et leur version. *Livrable* : Capture d'écran du résumé Nmap avec les versions découvertes.
2. **Fuzzing de Contenus Cachés** : Le serveur web héberge un portail non référencé. Téléchargez la wordlist du laboratoire et utilisez `gobuster` ou `ffuf` pour découvrir trois fichiers critiques avec l'extension `.bak` ou `.txt`. *Livrable* : Capture d'écran de la commande de fuzzing en cours d'exécution et des chemins trouvés.

3. Analyse du Contenu :

Téléchargez les fichiers cachés découverts. Ils contiennent des informations chiffrées/sensibles (des messages chiffrés ou des clés). Affichez leur contenu dans le terminal. *Livrable* : Capture d'écran de l'affichage du contenu.

Partie 3 : Cryptographie Opérationnelle (5 points)

Les fichiers récupérés lors de la Partie 2 contiennent un message chiffré en AES-256-CBC, ainsi que la clé et l'IV associés (au format hexadécimal ou base64).

1. **Déchiffrement Symétrique** : Utilisez `openssl enc -d -aes-256-cbc` avec les paramètres récupérés pour déchiffrer le message. Le message en clair contient un mot de passe temporaire. *Livrable* : Capture d'écran de la commande de déchiffrement et du mot de passe en clair.
2. **Chiffrement Asymétrique (RSA)** :
 - Générez une paire de clés RSA de 2048 bits sur votre machine.
 - Extrayez la clé publique.
 - Créez un fichier texte nommé `flag.txt` contenant le mot de passe déchiffré à l'étape précédente.
 - Chiffrez ce fichier avec votre clé publique et sauvegardez-le sous `flag.enc`.*Livrable* : Captures d'écran des commandes de génération de clés et de chiffrement.

Partie 4 : Exploitation d'Authentification (5 points)

Un service SSH et un formulaire d'administration HTTP tournent sur des ports non standards de la cible. Utilisez les dictionnaires `users.txt` et `passwords.txt`.

1. **Attaque par Dictionnaire (Hydra)** : Utilisez l'outil Hydra pour forcer l'accès au service SSH et au formulaire Web (selon les ports découverts lors de la Partie 2 - [Campus Portal](#)). *Livrable* : Capture d'écran de la commande Hydra avec l'option `-V` (verbeux) montrant le succès de l'attaque et la récupération des identifiants finaux.
2. **Preuve d'Accès** : Connectez-vous au service compromis en utilisant les identifiants trouvés. Exécutez la commande `whoami` puis `echo "Compromis par [Votre Nom]"`. *Livrable* : Capture d'écran finale validant votre accès au système cible.

Bon courage.